

Security Vulnerabilities in AI-Generated JavaScript: A Comparative Study of Large Language Models

Deniz Aydın^{*†} and Şerif Bahtiyar^{*}

^{*}Cyber Security and Privacy Research Lab, SPFLab, Istanbul Technical University, Maslak, Istanbul, Türkiye, 34469

Email: bahtiyars@itu.edu.tr

[†]Research and Development, Siemens A.Ş., Istanbul, Türkiye

Email: denizaydin@siemens.com

Abstract—Large Language Models (LLMs) have been widely used in software development, yet the security of AI-generated code remains a critical concern. This research examines security vulnerabilities in JavaScript code generated by six LLMs, which are ChatGPT-4o, Claude v3.5 Sonnet, DeepSeek R1 70B, Llama 3.1 405B, Mistral Large 2, and Nova Pro. We propose a new approach to assess security vulnerabilities. Using 100 identical complex prompts, we systematically assessed vulnerabilities in AI-generated code and analyzed the most frequently occurring Common Weakness Enumeration (CWE) categories in different LLMs. Our results show that 275 of the 600 generated JavaScript code snippets contain vulnerabilities. We also identify 602 vulnerabilities from 28 CWEs. While all LLMs introduce vulnerabilities into generated code, their CWE and severity distribution vary significantly. We also introduce metrics to ensure a fair comparison of LLM capabilities, such as Vulnerabilities per Line of Code (V/LoC) and Weighted Security Risk per Line of Code (WSR/LoC) as evaluation metrics. Our research highlights the need for security measures to mitigate the security risks in AI-generated code.

Index Terms—AI-Generated Code, Vulnerability, Common Weakness Enumerations, Security, Large Language Model

I. INTRODUCTION

Large Language Models have been widely adopted in software development, enabling developers to generate code efficiently. A recent survey conducted by GitHub reported that more than 97% of software developers utilized AI coding tools in their work at some point [21]. However, the security risks of AI-generated code remain a critical concern. Previous studies have shown that LLMs frequently introduce security vulnerabilities in their generated code [1] - [9]. Our research examines the security risks of AI-generated JavaScript code by analyzing the frequency, severity and Common Weakness Enumeration (CWE) distribution of vulnerabilities across different LLMs, providing a standardized assessment to compare their security performance and identify potential risks in AI-generated code. Specifically, we evaluated six commonly used LLMs from different companies that are ChatGPT-4o [22], Claude v3.5 Sonnet [23], DeepSeek R1 70B [24], Llama 3.1 405B [25], Mistral Large 2 [26] and Nova Pro [27]. For each LLM, we generated code snippets from 100 identical JavaScript prompts. The generated outputs were analyzed using a two-layered security assessment approach by combining Static Application Security Testing (SAST) tools, which are Semgrep [28], Snyk [29], and SonarCloud [30] with manual

code reviews to identify and classify vulnerabilities across distinct CWE categories.

We introduce a new approach to analyze AI-generated JavaScript code with two evaluation metrics that provide an accurate comparison between different LLMs, namely Vulnerabilities per Line of Code (V/LoC) and Weighted Security Risk per Line of Code (WSR/LoC). We use V/LoC because while comparing different LLMs' security, the number of vulnerabilities alone may be misleading due to variations in code length. For instance, Claude v3.5 Sonnet's generated JavaScript code snippets are approximately five times longer than ChatGPT-4o generated ones which makes direct vulnerability comparisons inaccurate. Similarly, WSR/LoC is introduced to address the varying severity of vulnerabilities between different LLMs as some models generate critical vulnerabilities more frequently than other models. Incorporating severity-based weighting, WSR/LoC enables a more accurate assessment of security risks across different models. The main contribution of this research is a new systematical evaluation of security risks about AI-generated JavaScript. Specifically, we analyzed vulnerability frequency, severity, and CWE distributions across different LLMs. Analysis results provide valuable insights into the security performance of AI code generation, introducing a structured evaluation for accurate assessment of LLMs.

In this research, we define a vulnerability as a weakness in the generated JavaScript code that could be exploited to compromise security categorized based on CWE. We define risk as the potential impact resulting from the exploitation of a vulnerability, considering severity levels according to Common Vulnerability Scoring System (CVSS) standards. The primary goal of this study is vulnerability analysis: identifying, classifying and quantifying vulnerabilities in AI-generated JavaScript code. Furthermore, we propose a severity-weighted evaluation metric (WSR/LoC) to assess the relative risk levels introduced by different LLMs.

The rest of the paper is organized as follows. Section II discusses AI-generated code and security. Section III describes the proposed methodology. Experimental evaluation results are presented in Section IV. The conclusion is given in Section V.

II. AI-GENERATED CODE AND SECURITY

Several studies have systematically evaluated security vulnerabilities present in AI-generated code, highlighting the

security risks of Large Language Models. The state of the art has shown that AI-generated code frequently contains exploitable vulnerabilities. One of the earliest research, Fu et al. [1] analyzed 452 code snippets produced by GitHub Copilot and found that 29.5% of Python and 24.5% of JavaScript snippets contain vulnerabilities spanning 43 different CWE categories. In another research, Tihanyi et al. [2] demonstrated that 51.24% of 112,000 ChatGPT-3.5 generated C programs contained vulnerabilities. Later, Tihanyi et al. [3] improved this research by including 9 other LLMs which resulted in 62.07% of the generated programs being vulnerable. In another research, approximately 40% of programs are discovered to be vulnerable [4]. A recent example shows that various programming languages with two different LLMs were analyzed, where their analysis showed that 49% to 55.5% of samples include at least one vulnerability depending on the LLM [5]. Other research studies also demonstrated the risk of using LLM introducing vulnerabilities in generated code [6]- [10].

Many research studies not only investigated security risks in AI-generated code but also conducted comparative analysis between AI-generated and human written code to evaluate their relative security implications. One such example is the research conducted by Hamer et al. [11], which demonstrated that ChatGPT generated code produces 20% fewer vulnerabilities than human generated code. Another similar research by Asare et al. [12] claims that AI is less likely to introduce vulnerabilities in code than humans. Similar experiments have been conducted by Sandoval et al. [13] which concluded that the usage of LLMs does not increase the incidence rate. Another important aspect is examined in Perry et al. [14] which shows that developers who have access to AI tools generated less secure code than developers coding without AI assistance where the AI assisted group exhibited increased confidence in the security of their code, leading to overlooked risks and improper security practices. Another research with conflicting conclusion conducted by Siddig et al. [15] showing that LLMs introduce a significant amount of code smells.

Several recent research studies have examined security implications of AI-generated code focusing on the assessment of LLMs in secure coding tasks. A comprehensive analysis by Sajadi et al. [16] investigates the effectiveness of LLMs in detecting vulnerabilities and reported a detection rate from 12.6% to 40%. Another similar research has been conducted by Ullah et al. [17] where various LLMs were analyzed for vulnerability evaluation which also reached a similar conclusion that LLM models are not yet capable for doing security evaluations.

Security evaluations of programs have been analyzed from many dimensions. For example, LLMs' capacity to be used in security related tasks have been examined by Tony et al. [18] where the authors created LLMSecEval dataset to assess the security of code generated by LLMs where each prompt corresponds to MITRE's Top 25 CWE list. Hajipour et al. [19] also created a similar dataset named CodeLMsec to evaluate vulnerabilities in Black-Box Code Language Models. A research with similar goal has performed by Yildirim et

al. [20] to evaluate different LLMs' performance for detecting API vulnerabilities. All of these studies show that metrics are needed to compare vulnerabilities between human generated codes and AI generated codes.

III. METHODOLOGY

In this research, the security of AI-generated JavaScript code is evaluated with different LLMs. A set of 100 identical prompts was provided to six distinct LLMs, and the generated outputs were systematically analyzed. The model of this research is shown in Figure 1.

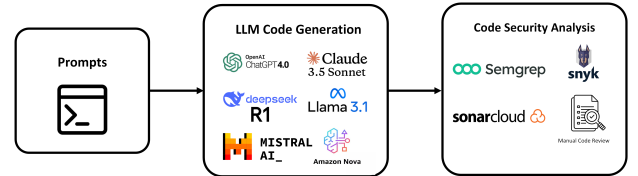


Fig. 1. Proposed model for security evaluation.

A. Prompt and LLM Selection

A structured approach was used to ensure comprehensive and robust evaluation of vulnerabilities in AI-generated code for prompt and LLM selections. For prompt selection, a set of complex JavaScript prompts was selected, where prompts were designed to test LLMs' capabilities to generate secure JavaScript code. The prompts were carefully chosen to include scenarios where LLMs might generate vulnerabilities that could result in various attacks, such as cross-site scripting (XSS), injection, and denial-of-service (DoS) attacks. To maintain consistency in the experiment, the same prompt texts were supplied to each LLM.

Six Large Language Models were chosen for LLM selection. Each LLM is developed by a different organization to ensure diversity in model architectures and training methodologies. The selected models include ChatGPT-4o, Claude v3.5 Sonnet, DeepSeek R1 70B, Llama 3.1 405B, Mistral Large 2 and Nova Pro. Details of the selected models can be found in Table I.

TABLE I
SELECTED LARGE LANGUAGE MODELS

Model	Creator	Context Window
ChatGPT-4o	OpenAI	128k
Claude v3.5 Sonnet	Anthropic	200k
DeepSeek R1 70B	DeepSeek	128k
Llama 3.1 405B	Meta	128k
Mistral Large 2	Mistral AI	128k
Nova Pro	Amazon	300k

B. Vulnerability Analysis

A two-layered security assessment process is proposed to analyze security vulnerabilities in AI-generated JavaScript code. The proposed approach combines automated security

testing tools and manual code reviews to ensure comprehensive vulnerability coverage. In the first stage, static application security testing (SAST) tools are used, such as Semgrep, Snyk and SonarCloud. In second stage, manual code reviews were conducted to validate the findings of the first stage. Additionally, logic-based vulnerabilities are analyzed. Moreover, vulnerabilities are categorized into appropriate CWE categories. This multi-layered hybrid approach ensured a broad coverage of vulnerabilities in AI-generated codes.

C. Evaluation Metrics

Initially, we used two metrics to evaluate the security of AI-generated codes, namely Total Vulnerable Prompts (TVP) and Total Vulnerability Count (TVC). TVP represents the total number of prompts that resulted in at least one vulnerability in generated JavaScript code snippet, measuring how frequently an LLM produces vulnerable codes. On the other hand, TVC measures the total number of security vulnerabilities detected across all generated outputs. Additionally, the metric is used to calculate cases where multiple vulnerabilities exist in the same output. While these two metrics provide a decent understanding of LLM's security performance, these metrics do not account for variations in output size, which may lead to biased comparisons when evaluating different LLMs.

A more fair metric is Vulnerabilities per Line of Code (V/LoC), which normalizes the number of vulnerabilities by the total lines of generated code. The metric ensures a fair comparison between LLMs that generate differing amounts of code, preventing models that produce longer outputs from being unfairly evaluated. V/LoC provides a normalized evaluation of vulnerabilities per line of generated code.

Another obstacle while evaluating different LLMs' capacity to generate secure code is the varying severity of vulnerabilities that are generated by each LLM. Until this point, evaluation metrics count low severity vulnerabilities same as critical severity vulnerabilities. To prevent this case, Weighted Security Risk per Line of Code (WSR/LoC) is introduced as an evaluation metric, which includes the Common Vulnerability Scoring System (CVSS) score of each vulnerability while comparing different LLMs. WSR/LoC is defined as follows.

$$WSR/LoC = \frac{\sum_i (CVSS_i \times V_i)}{LoC} \quad (1)$$

- WSR/LoC : Weighted Security Risk per Line of Code
- $CVSS_i$: Common Vulnerability Scoring System (CVSS) score of the i^{th} vulnerability
- V_i : Frequency of i^{th} vulnerability in the generated code
- LoC : Number of lines of code generated for LLM

The weighted security risk approach provides a more accurate assessment while comparing LLMs that produce a large number of low severity vulnerabilities versus LLMs that generate more severe vulnerabilities. By including WSR/LoC alongside commonly used evaluation metrics, this research provides a robust evaluation of LLMs in AI-assisted secure code generation.

IV. EXPERIMENTAL RESULTS

The security analysis of AI-generated JavaScript code with SAST tools and manual reviews revealed a significant number of vulnerabilities across all six large language models. A total of 600 code snippets were generated from 100 identical prompts in 6 different LLMs. Out of the 600 generated code snippets, 275 prompts (45.8%) produced vulnerable code. The results contain 602 vulnerabilities which are categorized into 28 different CWEs. Among the evaluated models, Mistral Large 2 produced the highest number of vulnerabilities, which is 148, followed by Llama 3.1 405B with 127 vulnerabilities, and Claude v3.5 Sonnet with 90 vulnerabilities. ChatGPT-4o produced the fewest vulnerabilities, 65, while DeepSeek R1 70B and Nova Pro produced moderate counts of vulnerabilities 85 and 87 respectively.

TABLE II
CWE FREQUENCY

	ChatGPT-4o	Claude v3.5 Sonnet	DeepSeek R1 70B	Llama 3.1 405B	Mistral Large 2	Nova Pro	Total
CWE-200	11	9	19	21	44	23	127
CWE-79	19	42	13	20	7	11	112
CWE-319	1	2	5	35	19	6	68
CWE-770	6	2	10	8	26	8	60
CWE-1333	4	11	10	1	1	3	30
CWE-22	4	0	3	3	14	4	28
CWE-942	0	1	8	0	0	18	27
CWE-89	0	5	4	14	2	2	27
CWE-327	4	2	3	2	4	3	18
CWE-1287	1	1	1	6	7	0	16
CWE-918	1	3	1	1	5	3	14
CWE-94	2	1	0	1	8	0	12
CWE-352	3	1	1	2	1	2	10
CWE-134	2	7	0	0	0	0	9
CWE-565	1	0	1	3	1	2	8
CWE-117	0	0	1	3	2	0	6
CWE-1321	0	0	0	1	4	0	5
CWE-1188	2	0	1	0	1	0	4
CWE-614	0	0	2	2	0	0	4
CWE-384	1	0	1	2	0	0	4
CWE-95	1	0	0	0	0	2	3
CWE-78	2	0	0	0	0	0	2
CWE-347	0	2	0	0	0	0	2
CWE-208	0	0	0	1	1	0	2
CWE-606	0	0	0	1	0	0	1
CWE-601	0	0	0	0	1	0	1
CWE-916	0	1	0	0	0	0	1
CWE-539	0	0	1	0	0	0	1
Total	65	90	85	127	148	87	602

The number of generated lines of JavaScript code varied significantly across different LLMs that potentially affects their vulnerability frequency. Claude v3.5 Sonnet generated the highest number of lines, which is 28,335, followed by Mistral Large 2 with 11,425, and DeepSeek R1 70B with 11,017. In contrast, ChatGPT-4o generated the fewest total lines, 5,820, which may contribute to its lowest vulnerability count as

higher LoC might have created greater code complexity which might lead to an increased number of produced vulnerabilities. Models such as Mistral Large 2 and Llama 3.1 405B, despite generating a moderate amount of code, 11,425 and 8,029, still recorded the highest vulnerabilities among the LLMs, suggesting that the nature of generated code plays a more significant role than the quantity of generated code in security risk assessment.

The frequency of different Common Weakness Enumeration (CWE) categories are determined based on detections in AI-generated JavaScript code across six LLMs, as shown in Table II. The most common vulnerability in AI-generated JavaScript code is CWE-200, known as Information Exposure, which appears 127 times, accounting for 21% of the reported vulnerabilities. CWE-79, Cross-Site Scripting (XSS) follows with 112 occurrences, approximately 18.6%, indicating a significant risk of insecure client-side scripting in AI-generated code. Additionally, CWE-319, Cleartext Transmission of Sensitive Information, was observed 68 times (11.3%), highlighting concerns about plaintext data handling. Other notable vulnerabilities include CWE-770, Allocation of Resources Without Limits, with 60 instances (10%), and CWE-1333, Inefficient Regular Expression Complexity, with 30 occurrences (5%). These results emphasize risks related to resource exhaustion and inefficient input validation. The five most common CWEs collectively contribute to 66% of all detected vulnerabilities in AI-generated JavaScript code, highlighting critical areas where AI-generated JavaScript is most prone to security risks.

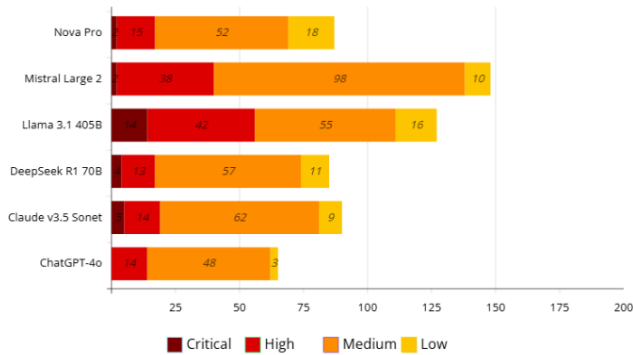


Fig. 2. The distribution of vulnerability severity.

The distribution of CWEs among the six evaluated LLMs revealed distinct results in their vulnerability distributions. Mistral Large 2 demonstrated a particularly high occurrence of CWE-200 with 44 instances, indicating a tendency to generate code that improperly exposed sensitive data compared to other LLMs. Llama 3.1 405B generated the highest number of CWE-89 vulnerabilities with 14 occurrences which is also known as SQL injection. These results suggest a greater risk of insecure data handling and improper sanitization of SQL inputs. Claude v3.5 Sonnet produced 42 instances of CWE-79, making it the most frequent LLM to generate XSS vulnerabilities. Meanwhile, DeepSeek R1 70B demonstrated a more evenly distributed set of vulnerabilities compared

to other LLMs but still contributed significantly to CWE-942, which is called Overly Permissive Cross-Domain Policy Violations, with 8 instances. While ChatGPT-4o produced the fewest vulnerabilities in overall, ChatGPT-4o still generates the high number of CWE-79 with 19 occurrences. Lastly, Nova Pro produced an unusually high 18 instances of CWE-942, indicating a recurring issue with security improper configurations. These differences in CWE distributions among different LLMs have likely happened due to variations in their model architectures, training methods, and prompt handling mechanisms.

The severity distribution results of vulnerabilities in AI-generated JavaScript code snippets are presented in Figure 2 and in Table III. The results highlight the dominance of severity medium vulnerabilities in all LLMs, which account for 372 instances, 61.8%, of all detected vulnerabilities. These results make medium severity vulnerabilities the most common severity type in AI-generated JavaScript code. High severity vulnerabilities appears as the second largest severity category with 136 occurrences, 22.6%. Llama 3.1 405B with 42 and Mistral Large 2 with 38 contribute to the counted results. Critical vulnerabilities, while relatively infrequent at 27 occurrences, 4.5%, still pose a significant security risk, particularly for Llama 3.1 405B with 14 occurrences. The low severity vulnerabilities represent 67 cases, 11.1%, with Nova Pro with 18 and Llama 3.1 405B with 16 occurrences. Thus, all models generate security vulnerabilities, but the distribution of severity levels varies significantly among them similar to CWE distribution.

TABLE III
SEVERITY DISTRIBUTION OF VULNERABILITIES IN AI-GENERATED JAVASCRIPT CODE

Severity	ChatGPT-4o	Claude v3.5 Sonnet	DeepSeek R1 70B	Llama 3.1 405B	Mistral Large 2	Nova Pro	Total
Critical	0	5	4	14	2	2	27
High	14	14	13	42	38	15	136
Medium	48	62	57	55	98	52	372
Low	3	9	11	16	10	18	67

The Total Vulnerable Prompts (TVP) and Total Vulnerability Count (TVC) differ significantly across the six evaluated LLMs, as shown in Table IV. This result highlights the variations in security risks associated with AI-generated JavaScript code. ChatGPT-4o has the lowest TVP with 37 and the lowest TVC with 65. In TVP comparison, ChatGPT-4o is closely followed by DeepSeek R1 70B with 38, Nova Pro with 38, and Claude Sonnet with 42, with their TVC ranging between 85 and 90. Mistral Large 2 and Llama 3.1 405B produced the highest number of vulnerable prompts, with 60 each, and the highest vulnerability counts, at 148 and 127, respectively. These results indicate that these LLMs are the most prone to

generating vulnerabilities in AI-generated JavaScript code.

Although TVC and TVP are widely used evaluation metrics in similar researches, they do not provide a fair comparison when evaluating different LLMs since Lines of Code (LoC) generated by each model vary significantly. For example, ChatGPT-4o generates the lowest amount of code, such as generating 5,820 LoC for 100 prompts, whereas for the same identical prompts, Claude v3.5 Sonnet generates 28,335 LoC, which is nearly five times larger than ChatGPT-4o. In this research, we used Vulnerability per Line of Code (V/LoC) to normalize the number of detected vulnerabilities based on the amount of generated code to ensure a more accurate evaluation. Table IV contains V/LoC across different LLMs, which shows the previously identified the most secure LLM ChatGPT-4o is now in the third position according to the V/LoC score with 0.0112, while Claude v3.5 Sonnet emerged as the most secure model with a V/LoC score of 0.0032 due to its significantly lower vulnerability density during generating a much larger quantity of code. This demonstrates the importance of using relative vulnerability metrics rather than absolute metrics when assessing different LLMs' capabilities.

TABLE IV
VULNERABILITY ANALYSIS OF AI-GENERATED JAVASCRIPT

	ChatGPT-4o	Claude v3.5 Sonnet	DeepSeek R1 70B	Llama 3.1 405B	Mistral Large 2	Nova Pro
Prompts	100	100	100	100	100	100
LoC	5,820	28,335	11,017	8,029	11,425	6,130
TVP	37	42	38	60	60	38
TVC	65	90	85	127	148	87
V/LoC	0.0112	0.0032	0.0077	0.0158	0.0130	0.0142
WSR/LoC	0.0656	0.0183	0.0433	0.1001	0.0772	0.0752

Weighted Security Risk per Line of Code (WSR/LoC) was used as an evaluation metric to provide a more comprehensive assessment of security risks, incorporating both the total number of vulnerabilities and their severity levels. While V/LoC helps normalize raw vulnerability counts relative to the amount of generated code, it does not differentiate between low-severity and critical-severity vulnerabilities. To address this gap, WSR/LoC assigns higher weights to critical and high-severity vulnerabilities, ensuring that LLMs producing a smaller number of severe security flaws are fairly penalized compared to those generating a higher volume of low-impact vulnerabilities. For instance, Mistral Large 2 has a better V/LoC score (0.0130) than Nova Pro (0.0142), since it generates fewer vulnerabilities per line of code, as shown in Table IV. However, Mistral Large 2 has a higher WSR/LoC score (0.0772) compared to Nova Pro (0.0752) because it generates more severe vulnerabilities. These evaluation metrics demonstrate that WSR/LoC provides a more meaningful security comparison across LLMs, ensuring models are assessed

based on both their vulnerability density and the severity of potential security flaws.

V. CONCLUSION

In this research, we propose a new approach to conduct a comprehensive security analysis of AI-generated JavaScript code across six Large Language Models, which are ChatGPT-4o, Claude v3.5 Sonnet, DeepSeek R1 70B, Llama 3.1 405B, Mistral Large 2, and Nova Pro. Our experimental analysis showed that the assessment of 600 AI-generated JavaScript code snippets contains 602 vulnerabilities from 275 vulnerable code snippets, demonstrating the security risks of AI-generated JavaScript code across different LLMs. While initial assessments were based on TVC and TVP, which provide an overview of each model's security performance, these metrics alone were insufficient for comparing LLMs due to differences in the number of LoC generated by each model, as well as the varying occurrence of vulnerabilities with different severity levels. To address this challenge, we used V/LoC and WSR/LoC. Performance analyses show that these metrics offer better accuracy in comparing different LLMs.

Beyond vulnerability metric comparison, analyzing CWE distributions was a crucial part of understanding the types of vulnerabilities in different LLMs. The frequency of different types of vulnerabilities across models highlights the specific security risks associated with each model. Moreover, the CWE analysis reveals the tendencies of different AI models to generate specific types of vulnerabilities in JavaScript code. Thus, the results indicate that the software development process involving AI-generated JavaScript code should be carefully reviewed to identify and mitigate potential vulnerabilities.

However, this study has several limitations. The analysis was limited to JavaScript code and a fixed set of 100 prompts, which may constrain the generalizability of the findings. Furthermore, the evaluation relied primarily on static analysis tools without dynamic or real-world testing environments. These factors should be considered when interpreting the results.

Future research could expand the range of prompts, include additional programming languages, and integrate dynamic analysis alongside static testing for a more comprehensive understanding. Further work on prompt engineering techniques and adversarial testing strategies could also uncover deeper vulnerability patterns.

ACKNOWLEDGMENTS

This work was supported by Research Fund of the Istanbul Technical University. Project Number: 45654

REFERENCES

- [1] Y. Fu et al., "Security Weaknesses of Copilot-Generated Code in GitHub Projects: An Empirical Study," *ACM Transactions on Software Engineering and Methodology*, vol. XX, no. X, Feb. 2025, doi: 10.1145/3716848.
- [2] N. Tihanyi, T. Bisztray, R. Jain, M. A. Ferrag, L. C. Cordeiro, and V. Mavroudis, "The FormAI Dataset: Generative AI in Software Security through the Lens of Formal Verification," *Proceedings of the ACM*, Dec. 2023, doi: 10.1145/3617555.3617874.

- [3] N. Tihanyi, T. Bisztray, M. A. Ferrag, R. Jain, and L. C. Cordeiro, "How secure is AI-generated code: A large-scale comparison of large language models," *Empirical Software Engineering*, vol. 30, no. 2, Dec. 2024, doi: 10.1007/s10664-024-10590-1.
- [4] H. Pearce, B. Ahmad, B. Tan, B. Dolan-Gavitt and R. Karri, "Asleep at the Keyboard? Assessing the Security of GitHub Copilot's Code Contributions," 2022 IEEE Symposium on Security and Privacy (SP), San Francisco, CA, USA, 2022, pp. 754-768, doi: 10.1109/SP46214.2022.9833571.
- [5] S. H. Ambati, N. Ridley, E. Branca and N. Stakhanova, "Navigating (in)Security of AI-Generated Code," 2024 IEEE International Conference on Cyber Security and Resilience (CSR), London, United Kingdom, 2024, pp. 1-8, doi: 10.1109/CSR61664.2024.10679468.
- [6] X. Yu, L. Liu, X. Hu, J. W. Keung, J. Liu and X. Xia, "Fight Fire With Fire: How Much Can We Trust ChatGPT on Source Code-Related Tasks?," in *IEEE Transactions on Software Engineering*, vol. 50, no. 12, pp. 3435-3453, Dec. 2024, doi: 10.1109/TSE.2024.3492204.
- [7] R. Khoury, A. R. Avila, J. Brunelle and B. M. Camara, "How Secure is Code Generated by ChatGPT?," 2023 IEEE International Conference on Systems, Man, and Cybernetics (SMC), Honolulu, Oahu, HI, USA, 2023, pp. 2445-2451, doi: 10.1109/SMC53992.2023.10394237.
- [8] M. Kharma, S. Choi, M. AlKhanafseh, and D. Mohaisen, "Security and Quality in LLM-Generated Code: A Multi-Language, Multi-Model Analysis," Feb. 2025, doi: 10.48550/arXiv.2502.01853.
- [9] V. Majdinasab, M. J. Bishop, S. Rasheed, A. Moradidakhel, A. Tahir and F. Khomh, "Assessing the Security of GitHub Copilot's Generated Code - A Targeted Replication Study," 2024 IEEE International Conference on Software Analysis, Evolution and Reengineering (SANER), Rovaniemi, Finland, 2024, pp. 435-444, doi: 10.1109/SANER60148.2024.00051.
- [10] T. E. Gasiba, A.-C. Iosif, I. Kessba, S. Amburi, U. Lechner, and M. Pinto-Albuquerque, "May the Source Be with You: On ChatGPT, Cybersecurity, and Secure Coding," *Information*, vol. 15, no. 9, p. 572, Sep. 2024, doi: 10.3390/info15090572.
- [11] S. Hamer, M. d'Amorim and L. Williams, "Just another copy and paste? Comparing the security vulnerabilities of ChatGPT generated code and StackOverflow answers," 2024 IEEE Security and Privacy Workshops (SPW), San Francisco, CA, USA, 2024, pp. 87-94, doi: 10.1109/SPW63631.2024.00014.
- [12] O. Asare, M. Nagappan, and N. Asokan, "Is GitHub's Copilot as bad as humans at introducing vulnerabilities in code?," *Empirical Software Engineering*, vol. 28, no. 6, Sep. 2023, doi: 10.1007/s10664-023-10380-1.
- [13] G. Sandoval, H. Pearce, T. Nys, R. Karri, S. Garg, and B. Dolan-Gavitt, "Lost at C: A user study on the security implications of large language model code assistants," *USENIX*, 2023. <https://www.usenix.org/conference/usenixsecurity23/presentation/sandoval>
- [14] N. Perry, M. Srivastava, D. Kumar, and D. Boneh, "Do users write more insecure code with AI assistants?," in *Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security (CCS '23)*, Copenhagen, Denmark, 2023, pp. 2785-2799, doi: 10.1145/3576915.3623157.
- [15] M. L. Siddiq, S. H. Majumder, M. R. Mim, S. Jajodia and J. C. S. Santos, "An Empirical Study of Code Smells in Transformer-based Code Generation Techniques," 2022 IEEE 22nd International Working Conference on Source Code Analysis and Manipulation (SCAM), Limassol, Cyprus, 2022, pp. 71-82, doi: 10.1109/SCAM55253.2022.00014.
- [16] A. Sajadi, B. Le, A. Nguyen, K. Damevski, and P. Chatterjee, "Do LLMs Consider Security? An Empirical Study on Responses to Programming Questions," *arXiv preprint arXiv:2502.14202*, Feb. 2025. [Online]. Available: <https://doi.org/10.48550/arXiv.2502.14202> unpublished.
- [17] S. Ullah, M. Han, S. Pujar, H. Pearce, A. Coskun and G. Stringhini, "LLMs Cannot Reliably Identify and Reason About Security Vulnerabilities (Yet?): A Comprehensive Evaluation, Framework, and Benchmarks," 2024 IEEE Symposium on Security and Privacy (SP), San Francisco, CA, USA, 2024, pp. 862-880, doi: 10.1109/SP54263.2024.00210.
- [18] A. Rydén, E. Näslund, E. M. Schiller, and M. Almgren, "LLMSECCode: Evaluating Large Language Models for Secure Coding," in *Lecture Notes in Computer Science*, 2024, pp. 100-118, doi: 10.1007/978-3-031-76934-4-7.
- [19] H. Hajipour, K. Hassler, T. Holz, L. Schönherr and M. Fritz, "CodeLM-Sec Benchmark: Systematically Evaluating and Finding Security Vulnerabilities in Black-Box Code Language Models," 2024 IEEE Conference on Secure and Trustworthy Machine Learning (SaTML), Toronto, ON, Canada, 2024, pp. 684-709, doi: 10.1109/SaTML59370.2024.00040.
- [20] R. Yıldırım, K. Aydın, and O. Çetin, "Evaluating the Impact of Conventional Code Analysis Against Large Language Models in API Vulnerability Detection," *EICC '24: Proceedings of the 2024 European Interdisciplinary Cybersecurity Conference*, pp. 57-64, Jun. 2024, doi: 10.1145/3655693.3655701.
- [21] K. Daigle, "Survey: The AI wave continues to grow on software development teams," *The GitHub Blog*, Aug. 20, 2024. [Online]. Available: <https://github.blog/news-insights/research/survey-ai-wave-grows/>
- [22] OpenAI, "ChatGPT-4o," OpenAI, May 2024. [Online]. Available: <https://openai.com/research/chatgpt-4o>
- [23] Anthropic, "Claude Sonnet v3.5," Anthropic, 2024. [Online]. Available: <https://www.anthropic.com>
- [24] DeepSeek AI, "DeepSeek R1 70B: A Large-Scale Language Model," DeepSeek AI, 2024. [Online]. Available: <https://www.deepseek.com>
- [25] Meta AI, "Llama v3.1 405B," Meta AI, 2024. [Online]. Available: <https://ai.meta.com/llama>
- [26] Mistral AI, "Mistral Large 2: High-performance language model," Mistral AI, 2024. [Online]. Available: <https://mistral.ai>
- [27] Amazon, "Nova Pro," Amazon, 2024. [Online]. Available: <https://aws.amazon.com/ai/generative-ai/nova/>
- [28] Semgrep, "Semgrep: Lightweight static analysis for security and code quality," r2c Inc., 2024. [Online]. Available: <https://semgrep.dev>
- [29] Snyk, "Snyk: Developer-first security platform," Snyk Ltd., 2024. [Online]. Available: <https://snyk.io>
- [30] SonarSource, "SonarCloud: Continuous Code Quality and Security," SonarSource, 2024. [Online]. Available: <https://sonarcloud.io>